Cloud Security Assessment Report

My-Test-Cloud

Scan ID 36c5eac33f1b · Generated 2026-10-12 21:18 · Prepared by AI Cloud Security Analyst

Facts in this report come from deterministic rules over the provided configuration. Sections labelled AI INTERPRETATION are model/template-written explanations and must be validated by an analyst. Attack paths are potential paths, not evidence of compromise.

1. Executive Summary

[FACT] 2 resources scanned; 4 findings; 1 potential attack paths; 9 activity alerts. Posture score 80/100.

[AI INTERPRETATION] Overall posture is 80/100. Potential attack path: an external actor could reach test-public-bucket directly from the internet. This is a possible exploitation path derived from configuration only; it does not mean an attack has occurred. Configuration findings describe weaknesses; activity alerts (9) describe possible misuse and need investigation.

[RECOMMENDATION] CSA-002:test-public-bucket: Enable S3 Block Public Access on the bucket and account, remove public ACLs/policies, serve public content via CloudFront if needed.

[RECOMMENDATION] CSA-009:test-public-bucket: Enable default encryption (SSE-S3/KMS for S3, storage encryption for RDS, EBS encryption by default). Existing RDS/EBS need snapshot-copy to encrypt.

[RECOMMENDATION] CSA-001:test-web-sg: Restrict TCP/22 to a bastion/VPN CIDR or remove it and use SSM Session Manager. Revoke the 0.0.0.0/0 rule.

2. Security Posture

Severity	Findings
CRITICAL	1
HIGH	3
MEDIUM	0
LOW	0

Score = 100 – Σ(finding risk / 15). Risk = severity base + exposure + data sensitivity + privileges + attack-path position, scaled by rule confidence.

3. Critical Findings

[CRITICAL] Public S3 bucket — test-public-bucket (risk 100/100)

[FACT] S3 bucket test-public-bucket allows public access and is classified as holding sensitive data.

[FACT] Evidence: {'public_access': True, 'data_classification': 'confidential', 'contains_sensitive_data': True}

Why it matters: Public buckets can be listed or read by anyone; misconfigured buckets are a leading cause of cloud data leaks.

Potential impact: Unauthorised disclosure of stored data; regulatory and reputational damage if the data is sensitive.

MITRE ATT&CK: T1530 Data from Cloud Storage (Collection). Limitation: A misconfiguration is only the precondition; there is no evidence of data collection unless access logs show it.

[RECOMMENDATION] Enable S3 Block Public Access on the bucket and account, remove public ACLs/policies, serve public content via CloudFront if needed.

4. High Findings

[HIGH] Missing encryption at rest — test-public-bucket (risk 83/100)

[FACT] S3 test-public-bucket has bucket default encryption disabled.

[FACT] Evidence: {'encrypted': False, 'contains_sensitive_data': True}

Why it matters: Encryption at rest limits the value of leaked snapshots, disks or storage media and is a common compliance requirement.

Potential impact: Data exposure if storage is copied, snapshotted or shared incorrectly.

[RECOMMENDATION] Enable default encryption (SSE-S3/KMS for S3, storage encryption for RDS, EBS encryption by default). Existing RDS/EBS need snapshot-copy to encrypt.

[HIGH] SSH exposed to the internet — test-web-sg (risk 65/100)

[FACT] Security group test-web-sg allows SSH (TCP/22) from anywhere on the internet.

[FACT] Evidence: {'offending_rules': [{'cidr': '0.0.0.0/0', 'protocol': 'tcp', 'from_port': 22, 'to_port': 22}], 'condition': 'ingress 0.0.0.0/0 TCP 22'}

Why it matters: SSH is a remote-administration channel. Open to 0.0.0.0/0 it is continuously scanned and brute-forced.

Potential impact: Remote shell access to instances; foothold for credential theft from the instance and lateral movement.

MITRE ATT&CK: T1133 External Remote Services (Initial Access / Persistence). Limitation: Exposure is not exploitation; the technique applies only if an actor actually authenticates.

[RECOMMENDATION] Restrict TCP/22 to a bastion/VPN CIDR or remove it and use SSM Session Manager. Revoke the 0.0.0.0/0 rule.

[HIGH] CloudTrail disabled or misconfigured — no-trail-configured (risk 55/100)

[FACT] No CloudTrail trail exists in this environment.

[FACT] Evidence: {'trails_found': 0}

Why it matters: CloudTrail is the audit log of API activity. Without it, incidents cannot be detected or investigated.

Potential impact: Attacker actions are invisible; forensics and compliance evidence are lost.

MITRE ATT&CK: T1562.008 Impair Defenses: Disable or Modify Cloud Logs (Defense Evasion). Limitation: A disabled trail may be a misconfiguration rather than an adversary action.

[RECOMMENDATION] Enable a multi-region trail with log file validation, deliver to a protected S3 bucket and alert on StopLogging/DeleteTrail.

5. Medium Findings

No findings at this severity.

6. Affected Resources

Resource	Type	Findings	Max risk
test-public-bucket	S3	CSA-002, CSA-009	100
test-web-sg	SecurityGroup	CSA-001	65
no-trail-configured	CloudTrail	CSA-005	55

7. Potential Attack Paths

AP-001 [CRITICAL] internet → test-public-bucket (risk 96)

[FACT] Findings enabling this path: CSA-002:test-public-bucket, CSA-009:test-public-bucket

Potential attack path: an external actor could reach test-public-bucket directly from the internet. This is a possible exploitation path derived from configuration only; it does not mean an attack has occurred.

Potential impact: Possible unauthorised access to sensitive data in test-public-bucket (S3)

• Internet -> test-public-bucket: public read access (bucket is public)

8. Cloud Activity Analysis

Activity alerts are indicators requiring investigation, not proof of compromise.

ID	Severity	Actor / IP	Alert
ALR-001	HIGH	dev-user 198.51.100.77	Repeated failed logins followed by a successful login
ALR-002	MEDIUM	dev-user 198.51.100.77	ConsoleLogin from an untrusted IP address
ALR-003	HIGH	dev-user 198.51.100.77	Privilege/identity change: CreateUser
ALR-004	HIGH	dev-user 198.51.100.77	Privilege/identity change: AttachUserPolicy
ALR-005	HIGH	dev-user 198.51.100.77	Privilege/identity change: CreateAccessKey
ALR-006	HIGH	dev-user 198.51.100.77	Possible persistence sequence: new user, policy attached, access key created
ALR-007	HIGH	backup-admin 198.51.100.77	Security group opened to the internet
ALR-008	CRITICAL	backup-admin 198.51.100.77	Audit logging changed: StopLogging
ALR-009	HIGH	backup-admin 198.51.100.77	Burst of object reads from a bucket

9. MITRE ATT&CK Mapping

Technique	Tactic	Source	Limitation
T1530 Data from Cloud Storage	Collection	CSA-002:test-public-bucket	A misconfiguration is only the precondition; there is no evidence of data collection unless access logs show it.
T1133 External Remote Services	Initial Access / Persistence	CSA-001:test-web-sg	Exposure is not exploitation; the technique applies only if an actor actually authenticates.
T1562.008 Impair Defenses: Disable or Modify Cloud Logs	Defense Evasion	CSA-005:no-trail-configured	A disabled trail may be a misconfiguration rather than an adversary action.
T1110 Brute Force	Credential Access	ALR-001	Could also be a user mistyping a password; confirm source IP and user intent.
T1078.004 Valid Accounts: Cloud Accounts	Initial Access / Persistence / Privilege Escalation	ALR-002	IP reputation/geolocation is not assessed; trusted ranges are configuration-based.
T1136.003 Create Account: Cloud Account	Persistence	ALR-003	Routine administration produces the same events; context (who/when/where) decides.
T1098 Account Manipulation	Persistence / Privilege Escalation	ALR-004	Routine administration produces the same events; context (who/when/where) decides.
T1098.001 Account Manipulation: Additional Cloud Credentials	Persistence	ALR-005	Routine administration produces the same events; context (who/when/where) decides.
T1136.003 Create Account: Cloud Account	Persistence	ALR-006	An administrator onboarding someone looks identical; check for a change ticket.
T1562.007 Impair Defenses: Disable or Modify Cloud Firewall	Defense Evasion	ALR-007	Mapping fits when done by an adversary; may also be an administrative mistake.
T1562.008 Impair Defenses: Disable or Modify Cloud Logs	Defense Evasion	ALR-008	Could be planned maintenance; validate against change records.

Technique	Tactic	Source	Limitation
T1530 Data from Cloud Storage	Collection	ALR-009	Backups and batch jobs generate similar bursts; no baseline of normal volume is modelled.

10. Risk Analysis

Finding	Score	Breakdown
CSA-002:test-public-bucket	100	75 severity + 10 exposure + 8 asset_sensitivity + 10 attack_path
CSA-009:test-public-bucket	83	55 severity + 10 exposure + 8 asset_sensitivity + 10 attack_path
CSA-001:test-web-sg	65	55 severity + 10 exposure
CSA-005:no-trail-configured	55	55 severity

11. Remediation Recommendations

[AI INTERPRETATION] Order of work favours findings with the highest risk score and those that sit on attack paths, since each fix there can break a whole chain. Test each change in a non-production account first, change one thing at a time and keep a rollback.

[RECOMMENDATION] CSA-002:test-public-bucket: Enable S3 Block Public Access on the bucket and account, remove public ACLs/policies, serve public content via CloudFront if needed.

[RECOMMENDATION] CSA-009:test-public-bucket: Enable default encryption (SSE-S3/KMS for S3, storage encryption for RDS, EBS encryption by default). Existing RDS/EBS need snapshot-copy to encrypt.

[RECOMMENDATION] CSA-001:test-web-sg: Restrict TCP/22 to a bastion/VPN CIDR or remove it and use SSM Session Manager. Revoke the 0.0.0.0/0 rule.

[RECOMMENDATION] CSA-005:no-trail-configured: Enable a multi-region trail with log file validation, deliver to a protected S3 bucket and alert on StopLogging/DeleteTrail.

12. AI-generated Investigation Summary

Generation mode: offline. Review before relying on it.

[FACT] Account My-Test-Cloud: 2 resources scanned, 4 findings (CRITICAL 1, HIGH 3, MEDIUM 0, LOW 0). Posture score 80/100.

[FACT] 1 potential attack path(s) identified; 9 activity alert(s) from 21 log events.

[FACT] AP-001 [CRITICAL, risk 96/100] potential path: internet -> test-public-bucket. Impact: Possible unauthorised access to sensitive data in test-public-bucket (S3). Linked findings: CSA-002:test-public-bucket, CSA-009:test-public-bucket

[FACT] CSA-002:test-public-bucket [CRITICAL, risk 100/100] Public S3 bucket on test-public-bucket (S3): S3 bucket test-public-bucket allows public access and is classified as holding sensitive data.

[FACT] CSA-009:test-public-bucket [HIGH, risk 83/100] Missing encryption at rest on test-public-bucket (S3): S3 test-public-bucket has bucket default encryption disabled.

[AI INTERPRETATION] Overall posture is 80/100. Potential attack path: an external actor could reach test-public-bucket directly from the internet. This is a possible exploitation path derived from configuration only; it does not mean an attack has occurred. Configuration findings describe weaknesses; activity alerts (9) describe possible misuse and need investigation.

Knowledge sources: s3_security.md — Block Public Access; s3_security.md — Encryption at rest; s3_security.md — Public buckets and data leaks

Appendix: Scope and Method

Data: simulated/synthetic resource configuration and CloudTrail-style events. Rules: CSA-001…CSA-010 (see docs). Limitations: no IAM condition/SCP/permission-boundary evaluation, no vulnerability scanning, no runtime

telemetry, simplified reachability model. CIS references are approximate pointers.

Resources scanned: test-web-sg, test-public-bucket